



The GitHub hack

It was one plugin away from being your problem too

Vyom Ramani | editor@digit.in

An infected VS Code extension compromised around 3,800 repositories owned by GitHub. And that's something that all developers around the globe must be wary of. It's not just any random user whose account got compromised. Nor was it some forgotten enterprise account that had been using a reused password. No, GitHub got hacked. GitHub – the company hosting the code for 90% of Fortune 100 companies.

In an official blog post, Microsoft's popular open-source development platform confirmed that it suffered an attack that saw around 3,800 of its own repositories breached by a threat actor calling itself TeamPCP. How the hackers pulled off the attack? One infected GitHub employee used a poisoned VS Code extension. Again, one plug-in and one computer. The attackers now have, allegedly, GitHub's own source code in their possession – including code for Copilot – which they are selling for at least \$50,000 on the dark web.

However, the good thing about this attack, according to GitHub's official statement, is that the customer data was unaffected.

The extension problem

VS Code has 50 million users. VS Code extensions marketplace has tens of thousands of plugins installed on developer machines working on critical infrastructure, sensitive proprietary code, and other production-related information. This is what security experts have been trying to say for several years already: VS Code plugins have complete access to all files on the machine, credentials, cloud keys, SSH keys, environment files – everything is readable and stealable.

On the very same day when the GitHub breach occurred, a totally unrelated plugin got infected with a backdoor. The infection lasted less than 20 minutes. Not long enough? Just remember that VS Code updates itself automatically, and 20 minutes would be

sufficient to infect tens of thousands of machines. Moreover, GitHub hasn't yet revealed the name of the plugin which was behind the company's breach, thus there is no way for developers to know whether they have been affected.

Who Is TeamPCP

TeamPCP has had an alarming 2026. Their hit list includes Aqua's Trivy scanner, CheckMarx's KICS, LiteLLM, TanStack, MistralAI, and packages that fed into those. They're behind Mini Shai-Hulud, a self-replicating supply chain worm that steals CI/CD credentials and uses them to publish infected versions of further packages, automating the spread of their own attacks across npm, PyPI, and VS Code extensions. Before GitHub, they'd already exfiltrated source code from Cisco.

This isn't opportunistic crime. It's methodical, industrial targeting of the infrastructure developers trust most.

What you should do

GitHub responded quickly, the extension was recalled, the device was quarantined, passwords were changed. But quarantine is containment, not prevention, and the trust model employed by the marketplaces will never work against this kind of attack. Verifying the publisher didn't help prevent the installation of the Nx Console backdoor. Even GitHub's own employee wasn't safe.

Review each and everyone of your API keys and secrets that are stored in private repositories. Audit every single one of your development machines for malicious VS Code extensions. View extensions as any other third-party code – guilty until proven innocent.

GitHub got breached. The company with some of the most security-savvy engineers in the world fell victim to a simple extension installation. If it can happen there, it can happen anywhere – and most companies lack even the minimal visibility into the developer's machine that GitHub had.

It is no longer about the perimeter. It is about your developer's machine. 